

theHarvester · Amass · Maltego

You've already used `theHarvester` and `Amass` in passing during the DNS/subdomain and email enumeration guides — this is the deep-dive on all three as dedicated OSINT tools, including Maltego, which you haven't covered yet and is genuinely a different category of tool (visual link-analysis, not just a CLI scanner).

PART 1: theHarvester

1. What It Is

`theHarvester` is a Python-based OSINT aggregation tool, pre-installed on Kali, that queries multiple public sources in one pass to pull **emails, subdomains, employee names, IPs, and URLs** tied to a target domain.

2. Basic Usage

```
theHarvester -d example.com -b google
theHarvester -d example.com -b bing
theHarvester -d example.com -b all           # query every configured source
theHarvester -d example.com -b all -l 500    # limit results per source
theHarvester -d example.com -b all -f report # save as report.html + report.xml
```

3. Key Flags

Flag	Meaning
<code>-d</code>	Target domain
<code>-b</code>	Data source (<code>google</code> , <code>bing</code> , <code>linkedin</code> , <code>crtsh</code> , <code>shodan</code> , <code>virustotal</code> , <code>all</code> , etc.)
<code>-l</code>	Limit number of results

Flag	Meaning
<code>-f</code>	Output filename (saves HTML + XML)
<code>-n</code>	Perform DNS resolution on discovered hosts
<code>-c</code>	Perform DNS brute-force on discovered domain
<code>-v</code>	Verify hosts via DNS resolution and search for virtual hosts

4. Sources It Can Query

- Search engines: Google, Bing, DuckDuckGo, Yahoo, Baidu
- Certificate transparency: **crt.sh** (same technique as your subdomain enum guide)
- **Shodan** (needs API key)
- **VirusTotal** (needs API key)
- **Hunter.io** (needs API key, email-focused)
- LinkedIn (limited, subject to anti-scraping changes)

Important practical note: many of the richer sources (Shodan, Hunter.io, VirusTotal) return nothing useful until you add free API keys to theHarvester's config file (`api-keys.yaml` in newer versions) — worth setting these up once so future scans return real data instead of empty results.

5. Example Output Interpretation

```
[*] Emails found: 12
    omkar.test@example.com
    admin@example.com

[*] Hosts found: 8
    mail.example.com:93.184.216.34
    dev.example.com:93.184.216.35

[*] Subdomains found: 15
```

This is your **first-pass raw intelligence dump** — not the final answer, but the seed list that feeds Amass, dorking, and email pattern-guessing.

6. Where It Fits

```
theHarvester = fast, broad, shallow first pass
Amass        = slow, thorough, deep follow-up
```

Common workflow: run `theHarvester` first for a quick sense of scope, then run `Amass` for exhaustive coverage.

PART 2: Amass

1. What It Is

OWASP Amass is the industry-standard tool for in-depth **attack surface mapping and asset discovery** — primarily known for subdomain enumeration, but it actually does much more: it builds a full network map (subdomains, IPs, ASNs, and relationships between them).

2. Amass Subcommands

```
amass enum      # subdomain/asset enumeration (the one yo
u'll use most)
amass intel     # discover root domains associated with a
n organization
amass viz       # visualize collected data (graphs, D3.js,
GEXF, etc.)
amass db        # query Amass's local results database
amass track     # track changes to a domain's assets over
time
```

3. `amass enum` — Core Usage

```
amass enum -d example.com
amass enum -passive -d example.com      # passiv
e-only, no active DNS resolution
amass enum -active -d example.com      # inclu
des active techniques (zone transfers, etc.)
amass enum -d example.com -o results.txt
amass enum -d example.com -brute      # add D
NS brute-forcing
amass enum -d example.com -brute -w wordlist.txt  # cust
```

```
om wordlist
amass enum -d example.com -src # show
which data source found each result
```

4. Data Sources Amass Pulls From

Amass aggregates from 40+ sources automatically — certificate transparency logs, DNS records, WHOIS, Shodan, Censys, GitHub, web archives, search engines, and more — without you manually running each one separately. This is its biggest advantage over [theHarvester](#): far more comprehensive coverage in a single command.

5. `amass intel` — Finding Related Root Domains

Useful when you only know an organization's name and need to discover *all* their domains, not just one you already know:

```
amass intel -org "Company Name"
amass intel -d example.com -whois # find other domains sharing WHOIS registrant info
```

This is genuinely valuable for engagements scoped to "the whole organization" rather than one specific domain — companies often have dozens of forgotten domains from acquisitions, old products, or regional sites.

6. `amass viz` — Visualizing Relationships

```
amass viz -d3 -dir amass_output/
amass viz -gexf -dir amass_output/ # export for Gephi (graph analysis tool)
```

Turns raw subdomain/IP data into a visual graph — useful for spotting clusters (e.g., "all these subdomains resolve to the same IP block, meaning shared infrastructure").

7. Practical Example — Full Workflow

```
# Step 1: find related root domains for the org
amass intel -org "Example Corp" -o roots.txt
```

```
# Step 2: deep enumeration on the primary domain
amass enum -d example.com -brute -active -src -o full_enum.txt

# Step 3: visualize the results
amass viz -d3 -dir amass_output/
```

8. Amass vs. theHarvester — Direct Comparison

	theHarvester	Amass
Speed	Fast	Slower, more thorough
Depth	Shallow (single-pass API queries)	Deep (40+ sources, recursive discovery)
Emails	Yes, strong focus	No, focused purely on assets/infrastructure
Subdomains	Basic	Extensive, industry standard
Visualization	None	Built-in (<code>amass viz</code>)
Best for	Quick recon, email harvesting	Serious attack-surface mapping

PART 3: Maltego

1. What It Is — A Fundamentally Different Tool Category

Maltego is a **graphical link-analysis platform**, not a CLI scanner. Instead of returning text/lists, it visually maps relationships between entities — domains, IPs, people, emails, companies, phone numbers, social media accounts — as an interactive node graph. It's built by Paterva, has a free **Community Edition (CE)**, and is widely used in both OSINT investigations and professional pentest recon.

Why this matters conceptually: `theHarvester` and `Amass` give you *lists*. Maltego gives you a *map showing how everything connects* — which is often the actual insight you need (e.g., "this employee's personal email is also linked to this leaked-credential-associated domain, which is hosted on the same IP as three other company assets").

2. Core Concepts

Entities — the "nodes" in Maltego (Domain, IP Address, Email Address, Person, Phrase, Website, Twitter Affiliation, etc.)

Transforms — the "actions" you run on an entity to discover *connected* entities. A transform is essentially a query that takes an input entity and returns related entities as new nodes.

Example logical flow:

```
[Domain: example.com]
  → run "To DNS Name" transform → [Subdomains]
  → run "To IP Address" transform → [IPs]
  → run "To Netblock" transform → [IP Ranges / ASN]
  → run "To Email Address" transform → [Emails]
  → run "To Person" transform → [Names]
```

Each arrow is a transform, and each result becomes a new node you can pivot from again — this chaining is Maltego's core value: manual OSINT means constantly switching between separate tools/browser tabs, Maltego keeps everything as one connected, growing graph.

3. Getting Started

1. Install Maltego (pre-installed on Kali, or download Community Edition from maltego.com)
2. Register for a free CE account (required even for the free tier)
3. Open a new graph
4. Drag a "Domain" entity onto the canvas, type in your target domain
5. Right-click → run transforms (e.g., "To DNS Name [DNS]")

4. Transform Hubs (Data Sources)

Maltego's transforms are powered by "Transform Hubs" — some free, some requiring paid API keys:

Hub	Provides
Standard Transforms (built-in, free)	Basic DNS, WHOIS, search engine results
Shodan Hub	Exposed services/devices linked to discovered IPs
HavelBeenPwned Hub	Breach data correlation for discovered emails
VirusTotal Hub	Malware/domain reputation data
Social Links Hub	Social media OSINT (often paid)

Hub	Provides
CTAS/CipherTrace	Blockchain/crypto tracing (specialized use cases)

The free Community Edition includes limited standard transforms — enough to learn the tool and do meaningful basic recon, but rate-limited and capped on result counts (paid versions remove these limits and unlock more transform hubs).

5. Practical Example — Company Recon Graph

A typical Maltego workflow for a company OSINT investigation:

```
Start: [Domain: company.com]
  ↓ To DNS Name           → subdomains appear as new nodes
  ↓ To IP Address         → each subdomain resolves to an IP
  ↓ To Netblock           → reveals the IP range/hosting provider
  ↓ To Email Address (from Domain) → discovers email addresses
  ↓ To Person (from Email) → attempts to link emails to real names
  ↓ To Website (from Person) → finds personal sites/social profiles
```

The resulting graph visually clusters everything — you can immediately *see* which subdomains share infrastructure, which emails belong to which apparent employees, and which nodes are dead ends vs. worth investigating further. This pattern-spotting is much harder to do by staring at flat text output from

[theHarvester](#) / [Amass](#) .

6. Machines — Automated Transform Chains

Maltego "Machines" run a whole sequence of transforms automatically instead of clicking through them one at a time — e.g., a "Company Stalker" machine (a well-known built-in example) automatically runs domain → email → social profile chains in one click, useful once you understand the manual process and want to speed up repeat engagements.

7. Where Maltego Fits Relative to theHarvester/Amass

	theHarvester	Amass	Maltego
Interface	CLI	CLI	GUI (visual graph)
Output	Text list	Text list / basic graph export	Interactive relationship graph
Best for	Quick email/subdomain	Deep, thorough asset discovery	Connecting disparate data types, spotting

	theHarvester	Amass	Maltego
	harvest		relationships, presenting findings
Learning curve	Low	Low-medium	Medium (transform/entity concepts take a session to click with)
Presentation value	Low (raw text)	Medium	High — graphs are genuinely useful in client-facing reports

Realistic workflow combining all three: run `theHarvester` and `Amass` first for raw data collection (they're faster and more thorough for pure enumeration), then import key findings into Maltego to visually map relationships and identify pivot points you might have missed just reading text output. Maltego also directly supports importing a CSV/text list of entities, so your `Amass` subdomain list can become the starting nodes for a Maltego graph rather than starting from scratch.

8. Practical Tip — Maltego CE Limitations

The free Community Edition:

- Requires an internet connection and Paterva account (no fully offline use)
- Caps results per transform (so a company with 500 subdomains won't show all 500 in one CE query)
- Limited to certain transform hubs

This is fine for learning and small-scope engagements/CTFs, but professional engagements with larger scope typically use a paid Maltego tier — worth knowing this distinction exists so you're not confused if a walkthrough you find online shows capabilities the free version doesn't have.

Putting All Three Together — A Combined Workflow

1. `theHarvester -d target.com -b all -f harvest_report`
→ fast first-pass: emails, subdomains, hosts
2. `amass enum -d target.com -brute -active -src -o amass_results.txt`
→ thorough, deep subdomain/asset discovery
3. `amass intel -org "Target Org" -o related_domains.txt`
→ discover any additional root domains tied to the org

4. Import amass_results.txt + harvested emails into Maltego
 - visually map how domains/IPs/emails/people connect
 - identify shared infrastructure, likely employee names, pivot points
5. Compile findings into a recon report
 - text data (theHarvester/Amass) + visual graph (Maltego) = a much stronger recon section than either alone

Kill Chain / ATT&CK Mapping

Tool	Framework Mapping
theHarvester	Reconnaissance — T1589.002 (Email Addresses), T1590.002 (DNS)
Amass	Reconnaissance — T1590.002 (DNS), T1596.001 (Passive DNS)
Maltego	Reconnaissance — spans multiple T1589/T1590/T1591 sub-techniques since it aggregates/visualizes across categories rather than being source-specific

Quick Reference Cheat Sheet

```
# theHarvester
theHarvester -d example.com -b all -f report

# Amass
amass enum -d example.com -brute -active -src -o results.txt
amass intel -org "Company Name" -o roots.txt
amass viz -d3 -dir amass_output/
```

Maltego (GUI workflow):

```
Domain entity → To DNS Name → To IP Address → To Netblock
               → To Email Address → To Person → To Website
```